

CYROPAY LTD

Data Protection Impact Assessment (DPIA)

Biometric Authentication Feature — Merchant Portal

Document ID: DPIA-001

Version: 1.0

Data Controller: CyroPay Ltd

Data Protection Officer: CyroPay DPO

Department: Product Engineering & GRC

Date Completed: May 2026

Review Date: May 2027

Status: Approved — Subject to DPO Sign-off

Document Classification: Confidential — Internal

CyroPay Ltd is a fictional organisation created for portfolio purposes. No real personal data or biometric data was used in the preparation of this document. This DPIA has been prepared in accordance with the ICO's DPIA guidance and the UK GDPR Article 35 requirements.

Step 1 — Describe the Processing

1.1 Nature of the Processing

CyroPay Ltd is introducing a biometric authentication feature for the Merchant Portal — the web and mobile interface used by merchant customers to access their CyroPay account, view transaction data, manage payment settings, and access financial reports.

The feature will allow merchants to authenticate using fingerprint recognition (on supported mobile devices) or facial recognition (on supported devices with front-facing camera hardware). Biometric authentication will be offered as an alternative to, and ultimately a replacement for, password-based login for merchant accounts.

Biometric data will be processed on-device using the device's native biometric hardware and operating system security enclave (e.g. Apple Secure Enclave, Android Strongbox). CyroPay systems will not receive, store, or process raw biometric templates. Authentication is confirmed to CyroPay via a cryptographic assertion from the device's trusted execution environment — consistent with a FIDO2 / WebAuthn implementation.

1.2 Purpose of the Processing

To improve the security of merchant portal authentication by replacing or supplementing password-based login with phishing-resistant biometric authentication.

To reduce account takeover fraud by eliminating the risk of credential phishing and password reuse attacks against merchant accounts.

To improve the merchant user experience by providing faster, frictionless authentication.

To support CyroPay's compliance with FCA operational resilience requirements and DORA ICT security obligations by strengthening access controls.

To align with ISO/IEC 27001:2022 Annex A control A.8.5 (Secure authentication) and A.5.17 (Authentication information) as documented in POL-004.

1.3 Legal Basis for Processing

Biometric data constitutes special category data under UK GDPR Article 9(1) where it is processed for the purpose of uniquely identifying a natural person. CyroPay's legal basis for processing biometric data under Article 9(2) is:

Legal Basis	UK GDPR Article	Applicability
Explicit consent of the data subject	Art. 9(2)(a)	Primary basis. Biometric authentication is opt-in. Merchants must provide explicit, granular, and freely given consent before enrolment. Consent can be withdrawn at any time without detriment to service access — password-based authentication remains available.
Substantial public interest	Art. 9(2)(g)	Not applicable — biometric authentication is a commercial feature, not a public interest activity.
Vital interests	Art. 9(2)(c)	Not applicable.

The lawful basis under Article 6 for the broader authentication processing activity is Article 6(1)(b) — processing necessary for the performance of the contract between CyroPay and the merchant. The additional special category condition under Article 9(2)(a) (explicit consent) applies specifically to biometric data.

1.4 Data Subjects

The data subjects are the individual users — typically merchant employees or sole traders — who hold CyroPay Merchant Portal accounts and choose to enrol in biometric authentication. Data subjects are adults operating in a commercial capacity.

1.5 Categories of Personal Data Processed

Data Category	Description	Special Category?	Retention
Biometric identifiers	On-device fingerprint or facial geometry data processed by the device OS security enclave. Raw biometric templates are NOT transmitted to or stored on CyroPay servers.	Yes — Art. 9(1) UK GDPR	Held on-device only. Deleted on de-enrolment or device wipe.
FIDO2 / WebAuthn public key	Cryptographic public key generated by the device during biometric enrolment registration. This is non-biometric data — it cannot be reverse-engineered to reconstruct biometric data.	No	Held in CyroPay systems for duration of enrolment. Deleted on de-enrolment.
Device identifier and attestation	Device model, OS version, and FIDO2 attestation certificate used to validate device trustworthiness during registration.	No	Held for duration of device registration. Deleted on device de-registration.
Authentication event log	Timestamp, device ID, and outcome (success/failure) of each authentication event. No biometric data included.	No	90 days — retained for security monitoring and fraud detection.
Enrolment consent	Record of merchant user's explicit consent to	No	Duration of merchant contract + 6 years

record	biometric enrolment, including timestamp and consent version.		(contractual evidence retention).
--------	---	--	-----------------------------------

1.6 Recipients and Data Flows

Recipient	Role	Data Shared	Safeguards
Device OS / Secure Enclave (Apple/Android)	Processes raw biometric data on-device	Biometric templates (never leave the device)	Apple Secure Enclave / Android Strongbox — hardware-level isolation. Data never accessible to CyroPay or third parties.
AWS (CyroPay cloud infrastructure)	Processor — hosts CyroPay Merchant Portal backend	FIDO2 public key, device attestation, authentication event logs, consent records	DPA in place. AWS SOC 2 Type II, ISO 27001. Encrypted at rest (AES-256) and in transit (TLS 1.3). UK/EU data residency (AWS eu-west-2 London region).
No other recipients	—	Biometric data and FIDO2 keys are NOT shared with Stripe, Salesforce, or any other third party.	N/A

1.7 Transfers outside the UK

No biometric data or FIDO2 cryptographic keys are transferred outside the United Kingdom. All CyroPay backend infrastructure is hosted in AWS eu-west-2 (London). Authentication event logs and consent records remain within the UK. No international transfers of special category data occur under this processing activity.

Step 2 — Necessity and Proportionality

2.1 Is the Processing Necessary?

Yes. The processing is necessary to achieve the stated purpose of strong, phishing-resistant merchant authentication. The following considerations support this conclusion:

Password-based authentication is the primary vector for account takeover fraud in the payments sector. Biometric authentication, implemented via FIDO2/WebAuthn, eliminates this risk class.

CyroPay's merchant accounts provide access to sensitive transaction data and payment configuration settings. The elevated authentication assurance provided by biometrics is proportionate to the sensitivity of this access.

The FCA and DORA both require regulated firms to implement strong authentication controls for access to sensitive systems. Biometric FIDO2 authentication satisfies the most stringent authentication requirements under these frameworks.

The on-device processing model means CyroPay does not hold or process raw biometric data, materially reducing the privacy risk compared to server-side biometric storage.

2.2 Proportionality Assessment

Factor	Assessment
Purpose limitation	Biometric data processed solely for authentication. No secondary use for profiling, analytics, or marketing. Technical controls prevent any use beyond authentication.
Data minimisation	On-device processing model ensures CyroPay receives only a cryptographic assertion — the minimum data necessary. Raw biometric templates never transmitted.
Accuracy	Device-native biometric processing (Apple/Android) provides high accuracy with low false positive and false negative rates. Fallback to password available for failed matches.
Storage limitation	FIDO2 public keys deleted immediately upon de-enrolment. Authentication logs retained for 90 days for security monitoring only. Consent records retained per legal obligation.
Integrity and	End-to-end encryption (TLS 1.3) in transit. AES-256

confidentiality	encryption at rest. FIDO2 public keys stored in a dedicated, access-controlled key store on AWS.
Opt-in with genuine alternative	Biometric authentication is strictly opt-in. Password-based login remains available without detriment. Merchants can withdraw consent and de-enrol at any time via account settings.

2.3 Alternatives Considered

The following alternatives were considered before selecting the FIDO2/WebAuthn on-device biometric approach:

Alternative	Considered?	Reason Not Selected
Server-side biometric template storage	Yes	Rejected — would require CyroPay to store raw biometric templates, creating a high-value target for attackers and significantly increasing the privacy risk and GDPR compliance burden.
Third-party biometric SaaS provider	Yes	Rejected — would introduce a third-party processor holding special category data, increasing supply chain risk and requiring additional contractual and DPIA considerations.
SMS / email OTP as enhanced authentication	Yes	Rejected as primary control — SMS OTP is vulnerable to SIM-swap attacks and does not satisfy phishing-resistant authentication requirements. Retained as fallback only.
Hardware security keys (FIDO2 only, no biometric)	Yes	Retained as an alternative for merchants who prefer not to use biometrics. Both options supported under the

		WebAuthn implementation.
FIDO2/WebAuthn on-device biometrics (selected)	Yes — Selected	Preferred option. Minimises data held by CyroPay, leverages device hardware security, provides phishing-resistant authentication, and aligns to ICO and NCSC guidance.

Step 3 — Identify and Assess the Risks

3.1 Risk Scoring Methodology

Risks are assessed using a 3x3 likelihood/severity matrix. Likelihood: 1=Low, 2=Medium, 3=High. Severity: 1=Low, 2=Medium, 3=High. Risk Score = Likelihood x Severity. Rating: 1-2=Low, 3-4=Medium, 6-9=High/Critical.

3.2 Risk Register

Risk ID	Risk	Likelihood	Severity	Score	Initial Rating
DR-001	Consent not freely given — merchant employees pressured by employers to enrol in biometrics as a condition of system access	2	3	6	High
DR-002	Inadequate consent mechanism — consent bundled with general T&Cs rather than obtained as a separate, explicit, granular act	2	3	6	High

DR-003	FIDO2 public key compromise — attacker gains access to CyroPay's key store and extracts public keys	1	2	2	Low
DR-004	Authentication event logs linked to individuals — logs used for purpose beyond security monitoring (e.g. HR surveillance, behavioural profiling)	2	3	6	High
DR-005	Data subject unable to exercise rights — merchant user cannot easily de-enrol, access their data, or withdraw consent	2	2	4	Medium
DR-006	Device compromise — attacker bypasses device biometric controls through OS vulnerability or physical coercion	2	3	6	High
DR-007	Vendor risk — Apple or Google OS update changes biometric API behaviour, causing authentication failures or data exposure	1	2	2	Low

DR-008	Inadequate retention and deletion — FIDO2 keys or consent records not deleted upon de-enrolment or account closure	2	2	4	Medium
DR-009	Cross-border transfer — future AWS infrastructure change routes authentication data outside the UK without DPA review	1	3	3	Medium
DR-010	Discrimination risk — biometric system performs less accurately for certain demographic groups, causing disproportionate authentication failures	2	3	6	High

Step 4 — Measures to Address the Risks

4.1 Risk Treatment Plan

Risk ID	Measure	Owner	Target	Residual Rating
DR-001	Biometric authentication must be positioned and communicated as strictly optional. The consent flow must explicitly state that password-based	DPO / Product	Launch	Residual Low

	login remains fully available. CyroPay Terms of Service updated to prohibit employers from mandating biometric enrolment. DPO to review consent UX copy before launch.			
DR-002	Implement a standalone, layered consent screen that: (a) explains what biometric data is; (b) states how it is processed on-device; (c) names CyroPay as data controller; (d) provides a link to the Privacy Notice; (e) requires an active tick-box. Consent must not be pre-ticked. Consent version and timestamp recorded per enrolment.	DPO / Engineering	Launch	Residual Low
DR-003	FIDO2 public keys are non-sensitive by design — they cannot be used to reconstruct biometric data or impersonate a user without possession of the registered device. Key store protected by AWS IAM least-privilege controls and encrypted at rest (AES-256). Access to key store logged	Engineering / CISO	Launch	Residual Low

	and audited. Key rotation capability implemented.			
DR-004	Authentication event logs must contain only: timestamp, device ID, merchant account ID (pseudonymised), and outcome. No biometric indicators, location data, or behavioural data included. Log access restricted to the Security Operations function. Formal policy prohibiting use of authentication logs for HR or management purposes. Log retention capped at 90 days with automated deletion.	CISO / DPO	Launch	Residual Low
DR-005	Merchant Portal to include a self-service biometric management page allowing users to: (a) view enrolled devices; (b) de-enrol individual devices; (c) withdraw consent and delete all biometric registration data; (d) submit a Subject Access Request. De-enrolment must trigger immediate deletion of FIDO2 public key and	Engineering / DPO	Launch	Residual Low

	device attestation from CyroPay systems. DPO to confirm rights fulfilment capability before launch.			
DR-006	On-device biometric processing relies on device OS and hardware security. CyroPay cannot fully mitigate device-level compromise. Residual risk accepted with the following compensating controls: device integrity check at authentication (FIDO2 attestation); anomalous authentication pattern detection via SIEM; account lockout on repeated authentication failures; merchant users advised in onboarding material to keep device OS updated.	Engineering / CISO	Launch	Residual Medium
DR-007	Monitor Apple and Google developer release notes for WebAuthn/biometric API changes. Include biometric authentication in quarterly application security testing scope. Fallback to password	Engineering	Ongoing	Residual Low

	authentication available at all times.			
DR-008	Implement automated deletion pipeline: de-enrolment event triggers immediate deletion of FIDO2 key and device attestation. Account closure triggers deletion of all biometric registration records. Consent records retained per contractual evidence obligation (6 years). Deletion confirmed and logged. DPO to audit deletion pipeline quarterly.	Engineering / DPO	Launch	Residual Low
DR-009	AWS infrastructure configuration locked to eu-west-2 (London) for all authentication services. Any change to AWS region configuration requires CISO and DPO sign-off and DPIA review. AWS DPA (UK GDPR compliant) in place.	CISO / Engineering	Launch	Residual Low
DR-010	Prior to launch, commission an independent bias and accuracy assessment of the biometric authentication feature across	DPO / Product	Pre-launch	Residual Medium

	representative demographic groups. Establish a monitoring programme to track authentication failure rates by device type. Password-based fallback always available for users experiencing disproportionate failure rates. If material bias is identified, feature must be paused pending remediation.			
--	--	--	--	--

Step 5 — Sign-off and Outcomes

5.1 DPO Opinion

Field	Detail
DPO Name	CyroPay Data Protection Officer
Opinion	The processing described in this DPIA is, subject to implementation of all measures identified in Step 4, compliant with UK GDPR requirements. The on-device FIDO2/WebAuthn model represents a privacy-by-design approach that minimises the personal data held by CyroPay to the greatest extent technically feasible. The opt-in consent model with genuine alternative satisfies the requirements of Article 9(2)(a). The residual risks identified (DR-006, DR-010) are accepted subject to the compensating controls described.
Recommendation	Proceed with implementation subject to DPO final review of consent UX copy, privacy notice updates, and confirmation of deletion pipeline testing before launch.
ICO Prior Consultation	No. Following implementation of the measures in Step 4,

Required?	residual risks do not meet the threshold for ICO prior consultation under UK GDPR Article 36. The on-device processing model, opt-in consent, and absence of server-side biometric storage materially reduce the risk level below the consultation threshold.
Date	May 2026
Signature	[DPO to sign]

5.2 Senior Responsible Owner Sign-off

Field	Detail
Name	Chief Executive Officer (CEO), CyroPay Ltd
Decision	Approved — proceed to implementation subject to DPO conditions
Date	May 2026
Signature	[CEO to sign]

5.3 Review Triggers

This DPIA must be reviewed and updated before any of the following changes:

- Addition of server-side biometric template storage.
- Introduction of a new biometric modality (e.g. voice recognition).
- Change of FIDO2 implementation provider or relying party configuration.
- Any change to AWS infrastructure that affects the data residency of authentication data.
- Material change to the consent mechanism or privacy notice.
- Any data breach or near-miss involving authentication or consent records.
- Annual review (next review: May 2027).

Step 6 — UK GDPR Compliance Checklist

Requirement	UK GDPR Reference	Status	Notes
-------------	-------------------	--------	-------

DPIA conducted before processing begins	Art. 35(1)	✓ Complete	DPIA completed prior to feature launch — May 2026
Special category data identified	Art. 9(1)	✓ Complete	Biometric data classified as special category
Explicit consent as processing condition	Art. 9(2)(a)	✓ Complete	Opt-in consent flow designed; DPO to review UX
Lawful basis under Art. 6 documented	Art. 6(1)(b)	✓ Complete	Performance of contract for authentication processing
Privacy Notice updated	Art. 13	In Progress	Privacy Notice must be updated before launch to describe biometric processing
Data minimisation applied	Art. 5(1)(c)	✓ Complete	On-device processing — no raw biometric data held by CyroPay
Purpose limitation documented	Art. 5(1)(b)	✓ Complete	Authentication only — no secondary use
Retention periods defined	Art. 5(1)(e)	✓ Complete	90 days (logs), enrolment duration (keys), 6 years (consent records)
Data subject rights implemented	Art. 15-22	In Progress	Self-service de-enrolment and rights portal — engineering in progress

DPIA reviewed by DPO	Art. 35(2)	✓ Complete	DPO opinion provided in Step 5
ICO prior consultation assessed	Art. 36	✓ Complete	Not required — residual risk below consultation threshold
Processor agreements in place (AWS)	Art. 28	✓ Complete	AWS DPA in place (confirmed in VRA-001)
No international transfer of biometric data	Art. 44-49	✓ Complete	All processing in AWS eu-west-2 London
Records of Processing Activities updated	Art. 30	In Progress	RoPA must be updated to include biometric authentication activity

Step 7 — Data Flow Summary

The following summarises the biometric authentication data flows. A full Data Flow Diagram is provided as a separate deliverable (DPIA-001-DFD).

Stage	What Happens	Data Involved	Where Processed	CyroPay Holds?
1. Enrolment — Device	Merchant user registers biometric on their device via device OS biometric API	Raw biometric template (fingerprint/face geometry)	On-device hardware security enclave (Apple/Android)	No — never leaves device
2. Enrolment	Device	FIDO2 private key	Private key: on-	Public key

— Key Generation	generates a FIDO2 key pair; private key stored in device secure element	(device only) + public key sent to CyroPay	device. Public key: AWS eu-west-2	only
3. Enrolment — Consent Recording	CyroPay records merchant user's explicit consent to biometric enrolment	Merchant user ID, consent timestamp, consent version, FIDO2 public key ID	AWS eu-west-2 (CyroPay)	Yes — for contract duration + 6 years
4. Authentication	Merchant presents biometric; device verifies against on-device template; device signs a challenge with FIDO2 private key; CyroPay verifies signature with public key	Authentication challenge/response; device attestation; auth event log entry	Verification: device + CyroPay AWS eu-west-2	Auth log only (90 days)
5. De-enrolment	Merchant withdraws consent or removes device; CyroPay deletes FIDO2 public key and attestation	FIDO2 public key and device attestation record deleted	AWS eu-west-2	Consent record retained (6 years); all other data deleted immediately

8. Related Documents

POL-006 Data Classification and Handling Policy
POL-004 Password and Authentication Policy
POL-005 Incident Response Policy
POL-008 Secure Development Policy
VRA-001 Amazon Web Services Vendor Risk Assessment
CyroPay Privacy Notice (to be updated before launch)
CyroPay Records of Processing Activities (RoPA) (to be updated)
DPIA-001-DFD Biometric Authentication Data Flow Diagram

9. Document Control

Version	Date	Author	Changes
1.0	May 2026	CyroPay DPO / GRC Team	Initial DPIA